

HALLAZGO DE VULNERABILIDAD EN LA BASE DE DATOS

INTRODUCCIÓN: se detecta vulnerabilidad en la base de datos de gravedad alta debido a la información valiosa y sensible que puede ser extraída como nombres de usuario o clientes.

DESCRIPCIÓN: por medio de la ejecución de una prueba de vulnerabilidad en la base de datos mediante la inyección de SQL, pudimos evidenciar la existencia de falla de configuración y validación por parte del sistema. quedando de esta manera expuesto totalmente el sistema a múltiples ataques de mayor envergadura por parte de ciberdelincuentes.

PROCESO DE REPRODUCCIÓN: se realizó la explotación de una vulnerabilidad mediante un ataque de inyección de SQL a la base de datos.

IMPACTO DEL INCIDENTE: el nivel de impacto de este incidente es superior, debido a la clase de información que se logró extraer, afectando directamente la confidencialidad de la información en la base de datos, de esta manera se le puede proporcionar al ciberdelincuente información crítica para escalar privilegios en el sistema y lograr control total sobre el mismo.

RECOMENDACIONES: para mitigar y prevenir esta vulnerabilidad se recomienda:

1. implementar un WAF (web application firewall) para optimizar las reglas que nos permita el filtrado de estas secuencias de inyección SQL y demás tráfico malicioso.
2. implementar IPS o IDS para monitorizar y bloquear actividades sospechosas.
3. realizar auditorías de forma regular para identificar y parchar las vulnerabilidades que se puedan encontrar en el sistema.
4. solicitar a los directivos capacitación para el equipo encargado de la programación del sistema, con el fin de corregir falencias y mejorar habilidades técnicas.

CONCLUSIÓN: en base a estos hechos en los que presento una violación grave a la seguridad de los recursos e información del sistema, se resalta la importancia de tener nuestros sistemas configurados correctamente y actualizados con las últimas versiones de

nuestros programas. adicionalmente contar con herramientas de seguridad que nos permitan monitorear el tráfico en la red.